

A Multi-Target Approach to Estimate Software Vulnerability
Characteristics and Severity Scores

Georgios Spanos , Lefteris Angelis

PII: S0164-1212(18)30206-1
DOI: <https://doi.org/10.1016/j.jss.2018.09.039>
Reference: JSS 10223



To appear in: *The Journal of Systems & Software*

Received date: 3 April 2018
Revised date: 19 July 2018
Accepted date: 12 September 2018

Please cite this article as: Georgios Spanos , Lefteris Angelis , A Multi-Target Approach to Estimate Software Vulnerability Characteristics and Severity Scores, *The Journal of Systems & Software* (2018), doi: <https://doi.org/10.1016/j.jss.2018.09.039>

This is a PDF file of an unedited manuscript that has been accepted for publication. As a service to our customers we are providing this early version of the manuscript. The manuscript will undergo copyediting, typesetting, and review of the resulting proof before it is published in its final form. Please note that during the production process errors may be discovered which could affect the content, and all legal disclaimers that apply to the journal pertain.

HIGHLIGHTS

- Multi-target & Text Analysis techniques to estimate vulnerability characteristics
- Enhancement, acceleration and support to specify vulnerability characteristics
- Predictability of vulnerability characteristics is relatively good
- Good accuracy of the calculated vulnerability scores

A Multi-Target Approach to Estimate Software Vulnerability Characteristics and Severity Scores

Georgios Spanos^a, Lefteris Angelis^{a*}

^a*School of Informatics, Aristotle University of Thessaloniki, Greece*

***Corresponding author:** Lefteris Angelis, lef@csd.auth.gr, School of Informatics, Aristotle University of Thessaloniki Campus, 54124, Thessaloniki, Greece

Abstract

Software vulnerabilities constitute a great risk for the IT community. The specification of the vulnerability characteristics is a crucial procedure, since the characteristics are used as input for a plethora of vulnerability scoring systems. Currently, the determination of the specific characteristics -that represent each vulnerability- is a process that is performed manually by the IT security experts. However, the vulnerability description can be very informative and useful to predict vulnerability characteristics. The primary goal of this research is the enhancement, the acceleration and the support of the manual procedure of the vulnerability characteristic assignment. To achieve this goal, a model, which combines texts analysis and multi-target classification techniques was developed. This model estimates the vulnerability characteristics and subsequently, calculates the vulnerability severity scores from the predicted characteristics. To perform the present research, a dataset that contains 99,091 records from a large -publicly available- vulnerability database was used. The results are encouraging, since they show accuracy in the prediction of the vulnerability characteristics and scores.

Keywords: Information Security, Software Vulnerability, Text Analysis, Multi-target Classification.

1. Introduction

Software vulnerabilities constitute a major threat in the contemporary society, where the vast majority of the human everyday processes are conducted with the support of information systems. A software vulnerability is a weakness, a bug or a hole that can be exploited by one or more threats, having as a result the impact to the confidentiality, the integrity and the availability of the affected computer systems (Mell et al., 2007, Schiffman and CISCO, 2005). The tremendous increase of software vulnerabilities has disquieted the IT security community -both practitioners and researchers of the area. The enormous number of recorded vulnerabilities (over 100,000) by the National Vulnerability Database¹ (NVD) reflects the magnitude of the problem. Additionally, a recent study supported that the vulnerability growth of Microsoft and Red Hat operating systems is sigmoidal (Ruohonen et al., 2015), showing a rapid growth. Finally, the most vulnerable/popular vendors, which have the most instances in the NVD according to a recent study (Zhang et al., 2015) are the: Linux, Sun, Cisco, Mozilla, Microsoft and Apple.

The ever-increasing problem of the vulnerabilities leads the researchers to try to predict them. Hence, regarding the vulnerability prediction, a related research found that software security vulnerabilities of the five most well-known browsers (Google Chrome, Mozilla Firefox, Internet Explorer, Safari and Opera) can be predicted quite accurate by time-series models with three components (trend, seasonality and level) and that the level component is the best estimator of these models (Roumani et al., 2015). Similarly, Murtaza et al. (2017) predicted with high accuracy the software vulnerabilities of the Windows and Linux operating systems, using sequential patterns that follow a Markov chain of first order, since the next vulnerability is predicted better, based only on the previous one. Finally, a recent survey (Ghaffarian and Shahriari, 2017) summarized the research work in the field of machine learning techniques for the software vulnerability analysis and discovery.

¹ <https://nvd.nist.gov/>

Regarding the vulnerabilities that are related to the emerging software for the mobile computing, virtualization, cloud computing and Internet of Things (IoT), there are also, several studies. For example, Chasaki and Mansour (2015) studied the security aspects of the IoT, such as the security requirements and the security threats. Moreover, Peng et al. (2013) proposed a system to detect vulnerabilities of ZigBee² on MAC layer. ZigBee is a wireless language that the everyday devices use to interact between them. Furthermore, Kuzuno and Tonami (2015) analyzed traffic and permissions of 1,188 Android applications and they proposed a system that generates signatures in order to detect sensitive information leakage. Similarly, to avoid information leakage from eavesdropping, Meng et al. (2013) proposed a routing-based approach to enhance the security of wireless sensor networks. Finally, Luan (2016) analyzed and discuss ways to exploit two critical vulnerabilities of Xen³ Hypervisor, which is a software that provides virtualization services.

Each vulnerability has specific properties and these properties can characterize a vulnerability. Some properties are related to the easiness or the difficulty of the vulnerability exploitation, such as the way the candidate vulnerable system can be accessed (remotely or locally) and the existence or not, of required authentication for accessing to the system. Respectively, some properties are related to the impact that a successfully exploited vulnerability will have to the confidentiality, the integrity and the availability of the system. The correct assignment of the vulnerability characteristics is crucial, since they constitute also, the input for many vulnerability scoring systems (First Organization, 2015; Liu and Zhang, 2011, Liu et al., 2012, Mell et al., 2007, Schiffman and CISCO, 2005, Spanos and Angelis, 2015, Spanos et al., 2015). The vulnerability scoring systems subsequently, are essential for the managers in order to assess, rank and prioritize the vulnerabilities. By a managerial point of view, the assessment of the vulnerability severity and the ranking of the vulnerabilities is a task of vital meaning, since it determines a) the magnitude of the urgency for the software patching and fixing and b) the ordering of these fixes.

² <http://www.zigbee.org/>

³ <https://www.xenproject.org/>

NVD is one of the largest vulnerability databases and publicly available. Each record in NVD includes -among other information- the vulnerability characteristics as determined by the security experts and the technical description, which is provided by the Common Vulnerabilities and Exposures⁴ (CVE). Hence, the specification of the vulnerability properties constitutes a manual procedure that is conducted by the IT Security experts of the NVD. It is obvious, that the quality of this process is absolute dependent on the human skills and capabilities. Furthermore, the manual procedure often leads to delays in the vulnerability characteristic assignment.

As reported by the study of Ruohonen (2017), although the median time for NVD experts to assign the vulnerability characteristics (and subsequently, the vulnerability severity score) is one day, the mean time is 134.7 days and the standard deviation 410.9 days. These statistical findings show an extremely skewed distribution regarding the response time for the vulnerability characteristic determination.

The present study follows the framework and the corresponding guidelines of a design science project (Von Alan et al., 2004; Wieringa, 2014), which constitutes a *solving-problem procedure*. Hence, by following this framework it is implied that the current research, designs and investigates a purposeful artifact in context for a specific problem. In the present research, the *artifact is the multi-target approach that combines text analysis and multi-target classification techniques and predicts the vulnerability characteristics and scores from the vulnerability description*.

The problem that the current research addresses is *the vulnerability characteristic determination and the vulnerability scoring*. As mentioned above, the characteristics of a vulnerability provide information about the vulnerability nature (regarding the exploitability and the impact of the vulnerability). Similarly, the vulnerability score, which is calculated by the vulnerability characteristics reflects the severity of the vulnerability. The vulnerability score is very important for the *IT Security Managers/Software Managers*, since it indicates how urgent a situation is and subsequently, how fast they should fix the software vulnerability. Moreover, the problem of the

⁴ <https://cve.mitre.org/>

vulnerability characterization concerns the *software developers/software architects* who may use vulnerable components in their code, since according to the severity/characteristics of the vulnerability they could decide whether they should keep or remove this component. Similarly, these details (characteristics and score) are important for the *users* of the vulnerable software, because by knowing this information, they could also estimate how the vulnerability of the specific software could be exploited and also evaluate the impact of a potentially successful attack.

According to the aforementioned problem definition and having in mind that the vulnerability characterization is currently conducted manually by the Security Experts of NVD, the goal of the present research is: *the support, the enhancement and the acceleration of the manual process*. This goal could be achieved by the artifact (estimation model) that has been described above, since the output of such a model will be the prediction of the vulnerability characteristics. This prediction can be used by the experts to support and enhance the manual characterization and furthermore can aid the automation of the characterization procedure, towards minimization of the human effort.

Concerned stakeholders of this methodology could be the security experts who characterize the vulnerability in order either to validate their choices before the publication of them or to have a recommendation before taking their decision. Moreover, this approach could be beneficial for the software vendors, since they will have a first view regarding the severity of their own vulnerabilities, prior to the final characterization that will be performed from NVD. Hence, the software managers could accelerate the ordering of the software patching, instead of waiting for the final decision from NVD which sometimes has significant delays. Finally, beyond IT security experts and software vendors, this multi-target approach could be useful for software developers that use vulnerable components in their code, but also for simple users of vulnerable well-known applications.

The rest of this paper is organized as follows: in Section 2 the related work is described, while in Section 3 the dataset is presented and in Section 4 the vulnerability scoring is discussed. Furthermore, in Section 5 the research methodology is described and the results of the research are

displayed in Section 6. Finally, in Section 7 there is the discussion about the research study and in the Section 8 the conclusions are summarized.

2. Related Work

The increase of the recorded software vulnerabilities and the appearance of available and diverse data sources for analyzing the different aspects of the software vulnerability problem has led the IT Security research community to publish several related studies during the last years.

Liu et al. (2012) classified software vulnerabilities into one of the following (pre-defined from themselves) categories: SQL Injection, Code Injection, Buff Errors and Access Issue, from related to vulnerabilities text that exists in various security websites. They conducted text analysis and classification with three different classifiers (k-Nearest Neighbor, Naïve Bayes and Support Vector Machine), in a sample of 1,060 vulnerabilities from Computer Emergency Readiness Team⁵ (CERT) and their results showed high accuracy (over 90%) in the vulnerability category prediction.

Na et al. (2016) by using the textual vulnerability overview of the NVD and by performing text analysis and classification with the Naïve Bayes classifier, they estimated the vulnerability type according to the Common Weaknesses Enumeration⁶ (CWE). They sampled only vulnerabilities that belong into one of the 10 most frequent categories, which have at least 1,000 records in the NVD. The results showed high accuracy (75%) in the vulnerability type classification.

Neuhaus and Zimmermann (2010) used the vulnerability textual description of the NVD and performed in a very large dataset of 39,393 records text analysis along with the unsupervised learning technique Latent Dirichlet Allocation (LDA). Their purpose was the development of a topic model, which will categorize automatically the vulnerabilities, instead of the manual classification performed by CWE. Their model resulted into 28 different topics, nine more than the 19 vulnerability types according to the schema of the CWE. Beyond the vulnerability classification, they conducted also, a trend analysis regarding the vulnerability types and characteristics.

⁵ <http://cert.org/>

⁶ <https://cwe.mitre.org/>

Toloudis et al. (2016) used the vulnerability technical description of the NVD and combined techniques of text analysis, Principal Components Analysis and correlation analysis. By performing their analysis in a very large dataset of 70,678 vulnerabilities, they found strong and statistically significant correlations between specific terms (or group of terms) and the vulnerability characteristics and scores.

Yamamoto et al. (2015) used also the NVD description of the vulnerabilities and applied natural language processing techniques along with machine learning algorithms (Naïve Bayes, LDA, Latent Semantic Indexing and Supervised LDA) in order to estimate the vulnerability characteristics. They applied their methodology in a dataset consisting of over 60,000 vulnerabilities, and the results showed good predictability. Finally, the results are even better when they used also as an estimation factor the annual effect.

In a recent conference paper, Spanos et al. (2017) exploited the technical description of 70,678 vulnerabilities from the NVD dataset in order to predict the vulnerability severity category (High, Medium or Low), according to two different vulnerability scoring systems. Three different classifiers were used in this study (Decision Tree, Neural Network and Support Vector Machine) and the severity prediction achieved high accuracy (around 80%).

It is obvious from the aforementioned that until now, there is not a research study that estimates the vulnerability characteristics *using a multi-target methodology*. The introduction of a multi-target approach, is the main novelty of this research, since considers relations between vulnerability characteristics that the paper of Yamamoto et al. (2015), which also estimates the vulnerability characteristics, does not. Furthermore, this research differentiates from the work of Spanos et al. (2017), which also estimates the vulnerability severity, because in the present research, the vulnerability severity scores (quantitative methodology) are calculated from the predicted characteristics, instead of the vulnerability severity ratings (qualitative methodology) that the previous related work predicts. Finally, the current study uses the biggest and most recent dataset in the related literature with almost 100,000 vulnerabilities that includes records up to 2018.

3. Dataset

The dataset that was used to conduct the current study is derived from the NVD, which is one of the largest and most popular vulnerability databases containing over 100,000 vulnerability records since 1988. NVD is a product of the Computer Security Division of the National Institute of Standards and Technology⁷ (NIST) and is funded by the United States Computer Emergency Readiness Team⁸ (US-CERT) of the Department of Homeland Security.

Each vulnerability record in NVD contains a lot of information related to the vulnerability such as: the id, the published datetime, the characteristics, the score, the source and the summary, which is the technical description of the vulnerability. From December 2015, there are two different schemas in NVD regarding the vulnerability characteristics, which are used respectively to calculate two different vulnerability scores. In the present study, the first and oldest schema was used, which is available for all the vulnerabilities and not only for the most recent -as the second schema is. The schema used, consists of a 6-dimensional vector of vulnerability characteristics, which are listed in Table 1. The ordering, in which the characteristic values are presented, reflects the vulnerability severity. For example, a vulnerability that can be exploited via Network is more severe than another that can be exploited locally having the same values in the five remaining characteristics.

The current dataset contains 99,091 vulnerabilities from 1988 until 2018. Each record in the dataset consists of the vulnerability characteristics and the textual description. In the present study, the records from 1988 until 2015, which correspond to 75156 vulnerabilities were used as the training set, whereas the newest one vulnerabilities from 2016 to 2018 (23935 records) were used as the test set of the methodology. This splitting of the dataset (the oldest vulnerabilities as the training set and the newest as the test set) follows the lines of the previous related work of Yamamoto et al. (2015) and also, is closer to the reality, since the characteristics and the score of the new vulnerabilities

⁷ <http://csrc.nist.gov/>

⁸ <https://www.us-cert.gov/>

will be estimated from a model that has been built from the existing vulnerabilities. An example of a dataset record is displayed in Table 2.

Table 1: Vulnerability Characteristics

Name	Description	Values	Category
Access Vector (AV)	The way with which a vulnerability can be exploited.	Local (L), Adjacent Network (AN), Network (N)	Exploitability
Access Complexity (AC)	The level of difficulty to access the candidate target.	High (H), Medium (M), Low (L)	Exploitability
Authentication (Au)	The level of authentication needed to access the vulnerable system.	Multiple Instances (MI), Single Instance (SI), None (N)	Exploitability
Confidentiality Impact (CI)	The impact to the confidentiality of the affected system	None (N), Partial (P), Complete (C)	Impact
Integrity Impact (II)	The impact to the integrity of the affected system.	None (N), Partial (P), Complete (C)	Impact
Availability Impact (AI)	The impact to the availability of the affected system.	None (N), Partial (P), Complete (C)	Impact

Table 2: A Dataset Record

Access Vector	Network
Access Complexity	Low
Authentication	Single Instance
Confidentiality Impact	Partial
Integrity Impact	None
Availability Impact	None
Technical Description	The RSM (aka RSMWinService) service in SolarWinds N-Able N-Central before 9.5.1.4514 uses the same password decryption key across different customers' installations, which makes it easier for remote authenticated users to obtain the cleartext domain-administrator password by locating the encrypted password within HTML source code and then leveraging knowledge of this key from another installation.

4. Vulnerability Scoring

IT Security and Software Managers need a reliable way to assess the vulnerability severity and to prioritize the vulnerabilities accordingly. In this section, the two vulnerability scoring systems, which are included in the proposed methodology and are trying to address this problem, are described: The Common Vulnerability Scoring System (CVSS), (Mell et al., 2007) and the Weighted Impact Vulnerability Scoring System (WIVSS), (Spanos and Angelis, 2015).

CVSS is the de-facto scoring system of the IT security community to score and prioritize vulnerabilities. The popularity and the wide acceptance of the system is reflected by the selection of CVSS to be the official score of the NVD. Three different versions of CVSS were published until now, the first version of CVSS was published in 2005 (Schiffman and Cisco, 2005) and uses 9 factors to compute the final vulnerability score; the second in 2007 (Mell et al., 2007), which uses for the calculation of the score, the six characteristics that were presented in the previous Section; and the last one in 2015 (First, 2015) that computes the vulnerability score according to 8 factors. NVD now uses in parallel CVSS version 2 and CVSS version 3. The CVSS version 2 that uses the schema of NVD with the 6 vulnerability characteristics was used in this research because of its availability in the whole database of NVD.

WIVSS is an alternative scoring system that uses the same vulnerability schema with CVSS version 2, but considers more important and scores higher the confidentiality-related vulnerabilities, second more important the integrity-related and last the availability-related vulnerabilities. This different scoring of WIVSS, regarding the impact of the vulnerability, is the main difference with the CVSS that considers equally the Confidentiality, Integrity and Availability Impact. WIVSS was introduced in 2013 (Spanos et al., 2013), while an improvement of WIVSS that found the optimal weights from an exhaustive algorithm, was presented in 2015 (Spanos and Angelis, 2015). WIVSS achieved improved score accuracy and higher diversity of values in comparison with CVSS (Spanos and Angelis, 2015) and for this reason was selected as the second vulnerability scoring system in the current methodology.

Both systems have scoring range 0.0-10.0. The weights (Table 3) and the calculation formulas of the CVSS and WIVSS are following:

$$CVSS = RoundTo1Decimal (((0.6 * Impact Score) + 0.4 * Exploitability Score) - 1.5) * f(Impact)),$$

where,

$$Impact Score = 10.41 * (1 - (1 - Confidentiality Impact) * (1 - Integrity Impact) * (1 - Availability Impact)),$$

Exploitability Score = $20 * \text{Access Vector} * \text{Access Complexity} * \text{Authentication}$

and,

$f(\text{Impact}) = 0$ if **Impact Score** = 0 and $f(\text{Impact}) = 1.176$ otherwise.

WIVSS = $\text{RoundTo1Decimal} ((\text{Exploitability Score} + \text{Impact Score}) * f(\text{Impact}))$,

where,

Impact Score = **Confidentiality Impact** + **Integrity Impact** + **Availability Impact**,

Exploitability Score = $6 * \text{Access Vector} * \text{Access Complexity} * \text{Authentication}$

and,

$f(\text{Impact}) = 0$ if **Impact Score** = 0 and $f(\text{Impact}) = 1.176$ otherwise.

Table 3: The weights of CVSS & WIVSS

Metric Name	Values	CVSS Weights	WIVSS Weights
Access Vector	Local, Adjacent Network, Network	0.395, 0.646, 1	0.395, 0.646, 1
Access Complexity	High, Medium, Low	0.35, 0.61, 0.71	0.35, 0.61, 0.71
Authentication	None, Single Instance, Multiple Instances	0.45, 0.56, 0.704	0.45, 0.56, 0.704
Confidentiality Impact	None, Partial, Complete	0.0, 1.5, 3.0	0.0, 1.8, 3.6
Integrity Impact	None, Partial, Complete	0.0, 1.5, 3.0	0.0, 1.1, 2.2
Availability Impact	None, Partial, Complete	0.0, 1.5, 3.0	0.0, 0.6, 1.2

5. Research Methodology

First of all, since the purpose of this research is the estimation of the vulnerability characteristics and scores from their technical description (which was presented in third section), the first technique that should be used in the proposed methodology is the natural language processing of the description text. This first step is mandatory and also, a pre-requisite in order to transform the unstructured natural language to a structured dataset that could be used by analyzing algorithms.

Furthermore, the first part of the output of the proposed methodology should be the simultaneous prediction of vulnerability characteristics: *Access Vector*, *Access Complexity*, *Authentication*, *Confidentiality Impact*, *Integrity Impact* and *Availability Impact*. In contrast to previous works, the

current research considers and attempts to estimate the vulnerability properties as a vector of multiple characteristics and not as individual characteristics. This consideration is influenced by the study of Spanos and Angelis (2015), which discovered strong correlations between vulnerability characteristics, using Multiple Correspondence Analysis and chi-square tests. For this reason, the present research uses -along with the text analysis- multi-target classification to predict the vulnerability characteristics as a vector of multiple outputs.

Regarding the multi-target classification, this includes: a) the transformation of the dataset and b) the classification. The method to transform the dataset is the Label Powerset (LP), (Boutell et al., 2004), a simple and straightforward multi-label method that -as its name indicates- considers each different combination of labels that exists in the dataset as a different class. The efficiency combined with simplicity, make the LP method as a benchmark transformation algorithm (Cerri et al., 2009, Cheng and Hüllermeier, 2009). LP was selected in the proposed methodology due to the above considerations and the fact that this multi-label technique can be adapted to the present multi-target classification problem. The adoption of multi-label techniques is inspired by the study of Xioufis et al. (2016), who used adaptations of multi-label classification methods in order to perform multi-target regression.

Moreover, three different machine learning algorithms were selected to perform the classification part of the methodology. These are the Random Forest (Breiman, 2001), the Boosting (Freund and Schapire, 1996) and the Decision Tree (Quinlan, 1993). The superiority of the Random Forest over simple machine learning algorithms and generally, the very high standards of performance can be reflected in several previous studies (Caruana and Niculescu-Mizil, 2006, Caruana et al., 2008, Fernández-Delgado et al., 2014, Meire et al., 2016). Moreover, Random Forest has the advantage that it doesn't present the typical problem of other ensemble classifiers, namely the overfitting (Breiman, 2001). Similarly, the Boosting algorithm, as an ensemble machine learning algorithm, outperforms the single machine learning algorithms and achieves high performance, as reflected by numerous studies in the literature (Belayneh et al., 2016, Caruana and Niculescu-Mizil, 2006,

Caruana et al., 2008). Finally, Decision Tree is a well-established and very popular machine learning algorithm, which presented good performance in previous studies in the information security field (Chen et al., 2011, Nishanth et al., 2012, Spanos et al., 2017). For all these reasons, the Random Forest, the Boosting and the Decision Tree were selected for the classification part of the proposed methodology.

During the last years, the aforementioned techniques of natural language processing and multi-label classification, have been very popular due to their efficiency and for this reason, several previous studies in various research fields have used text analysis (Balan and Conlon, 2016, Chan and Chong, 2017, Chen et al., 2011, Theodosiou et al., 2008), multi label classification (Cesa-Bianchi and Valentini, 2012, Huang et al., 2005, Xioufis et al., 2011) or a combination of these methods (Mencia and Fürnkranz, 2008, Tsoumakas et al., 2014, Xioufis et al., 2011).

Finally, the last part of the methodology is the computation of the vulnerability severity scores from the predicted characteristics. The vulnerability scoring systems CVSS and WIVSS were used in the present methodology in order to calculate the vulnerability scores. These two vulnerability scoring systems were selected in the methodology for the reasons that have been described in the previous section.

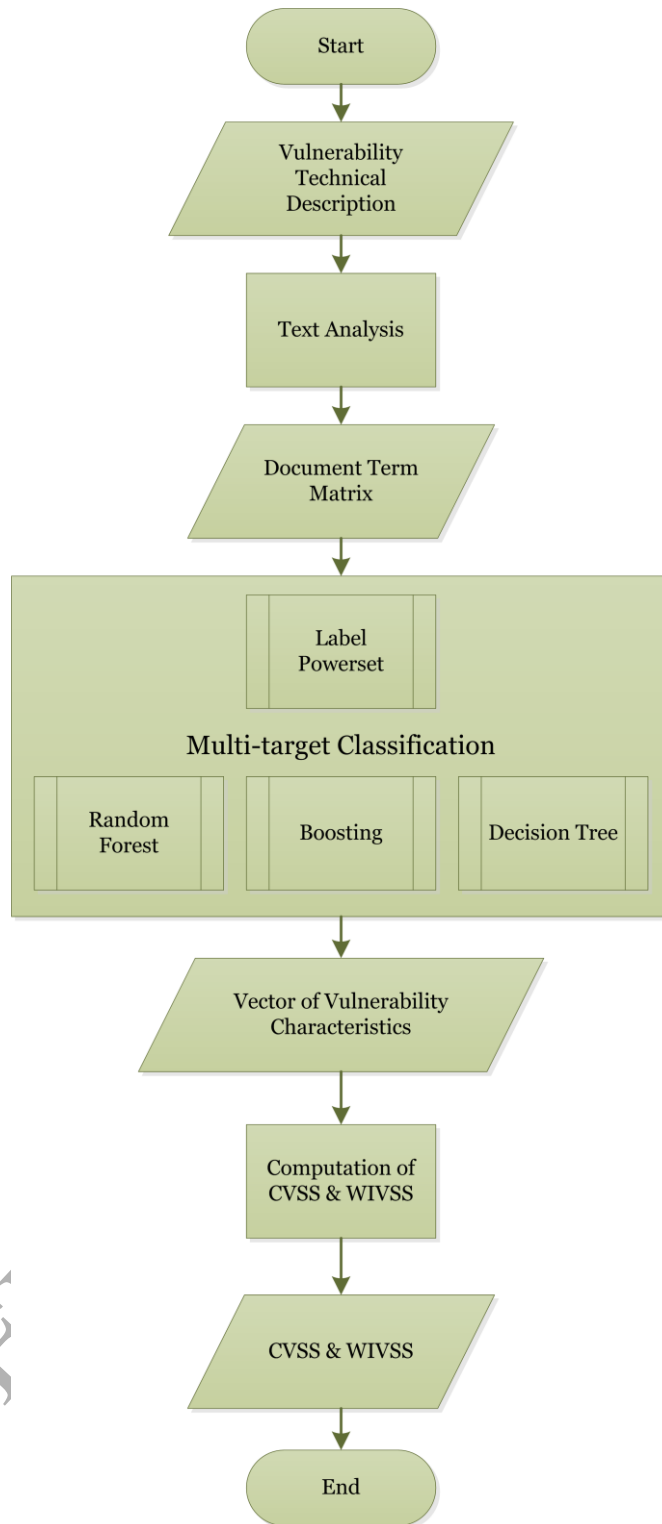


Figure 1: The steps of the methodology

Figure 1 portrays the steps of the proposed methodology, from the processing of the vulnerability description until the prediction of the characteristics and the calculation of the scores. The first stage of the methodology is the text analysis (Chowdhury, 2003), which is applied to the vulnerability textual description, having as goal the transformation of the text, which constitutes a form of

unstructured data, to a representation appropriate for further analysis, such as the Document-Term Matrix (DTM), (Williams, 2016). DTM is a simple matrix where each row corresponds to a document (the document in this case is the vulnerability technical description) and each column to a term, whereas the values in the cells represent the number of term appearances in a document. Intermediate steps to result to DTM are: a) the removal of stop words, punctuation, numbers and any other meaningless words, b) the transformation of specific words, c) the stemming and c) the removal of extremely infrequent terms (frequency < 0.1% of the vulnerability descriptions), (Williams, 2016). The determination of the final terms is performed **only to the training set** and these terms were used also in the creation of the DTM for the test set. New terms could not be extracted from the test set, because in a real situation problem (predict characteristics & score from a description for a new vulnerability), the terms which are essentially the predictors, should be already known and be included in the estimation model, which has been built from the training set.

The second phase of the methodology includes the multi-target classification, which is a generalization of the multi-label classification (Tsoumakos and Katakis, 2011). In this phase the algorithm takes as input the extracted from the previous step DTM that contains the independent variables of the classification, i.e. the term frequencies in the vulnerability descriptions. Since, the purpose of this research is to estimate the entire vector of the vulnerability characteristics, this problem can be defined as a multi-target classification problem, where each vulnerability consists of exact 6 targets -corresponding to the vulnerability characteristics- and each target can take three possible values. For example, the dataset record that was presented in Table 2, represents a vulnerability that has the following targets: {**AV**: N, **AC**: L, **Au**: SI, **CI**: P, **II**: N, **AI**: N}. Hence, all the possible combinations of targets for the vulnerability characteristics are 3^6 (=729).

As observed in Figure 1, the multi-target classification contains 2 sub-processes. The first sub-process is the transformation of the dataset -and specifically, the vector of the vulnerability characteristics that will be estimated- in such a form that multi-class classification algorithms can be applied. By using the LP transformation algorithm (adapted in such way that can accept values

different from 0 and 1), the vulnerability example of the previous paragraph -that shows the vector of the targets- will be transformed to a string representing a simple class and including the values of the targets divided by a blank space {N L SI P N N}.

Thus, after the execution of the LP transformation algorithm, the problem now can be considered as a common single-target classification problem, since the dependent variable consists of multiple classes (one of these classes is the string {N L SI P N N}, which mentioned above). Subsequently, the second sub-process of the multi-target classification step, for the proposed methodology, is the classification using the three machine learning algorithms: *Random Forest*, *Boosting* and *Decision Tree*.

Random Forest is an iterative algorithm that belongs to the family of the ensemble classifiers, since the outcome of the classifier is the average prediction of all the classification trees that have been created during the execution of the algorithm. This algorithm -as its name reflects- is based in the randomness, which exists in two layers: a) in the random selection of the sample data for each iteration, which is performed as in the bagging algorithm (Breiman, 1996), where each training set is drawn from the original training set with replacement, and b) in the random selection of the variables-predictors to build each classification tree, which is based in the random subspace method (Ho, 1998). The Strong Law of Large Numbers indicates that the overfitting of the model is avoided (Breiman, 2001). Furthermore, only two parameters should be set and tuned to conduct the algorithm and optimize the results: the number of trees and the number of predictors (Bogaert et al., 2016, Meire et al., 2016). The tuning of these parameters follows the guidelines of Breiman (2001) and of previous studies that implement the Random Forest ensemble classifier (Bogaert et al., 2016, Liaw and Wiener, 2002, Meire et al., 2016). Hence, different numbers of trees were tested, in order to improve the prediction and the final number of trees was set to 1000 (a quite large number to get stable results as the guidelines advice). Similarly, different numbers of predictors were tested (including the suggested values of Breiman (Liaw and Wiener, 2002): the square root of the total predictors, which is the default value, the half of the default value and the double of the default

value) and the number of predictors was set to 40 (from a total of 258 predictors). For the tuning of these two parameters (number of predictors and trees), the common k-fold cross-validation and specifically the 5-fold cross validation was used in the training set. Therefore, the factor to tune the parameters was the averaging results of the 5-fold cross validation.

Boosting is also, an algorithm that belongs to the family of ensemble algorithms (as the Random Forest) and the final outcome is derived from the cumulative voting of all the classifiers, which have been built during the process. The boosting algorithm that was used in the present methodology is part of the C5.0 classification model (Kuhn and Johnson, 2013, Rulequest Research, 2018) and is similar to the Adaptive Boosting (AdaBoost) (Freund and Schapire, 1997), where in each iteration, the algorithm builds the classification tree by paying more attention to the cases that have been previously predicted erroneously. This building of the classification trees is different in comparison with the random reasoning in the tree construction of Random Forest. Moreover, the algorithm stops when the error of the most recent classifiers becomes extremely low or high (Kuhn and Johnson, 2013). Finally, regarding the number of trees, the algorithm stopped to 25 iterations and this is also the final number of trees for the Boosting algorithm.

Decision Tree is a very popular classifier, the base for many ensemble classifiers (including the Random Forest and the Boosting) and is depicted as its name reflects as a tree-graph. Each internal node of the tree represents a feature-based condition (e.g. feature 1 < 10), the branches below each node depict the output of the condition (true or false) and finally, the leafs (or terminal nodes) represent the output of the Decision Tree algorithm (e.g. Class A). Decision Tree is also, very efficient with categorical data and tolerant in the presence of outliers and missing data. In the present methodology the C5.0 version (Kuhn and Johnson, 2013, Rulequest Research, 2018) of Decision Tree was adopted, which is an improvement of the C4.5 algorithm (Quinlan, 1993). This Decision Tree version allows multiple splits at any level of the tree, is faster, more accurate and more efficient regarding memory usage, in comparison with C4.5 (Rulequest Research, 2017).

Finally, after the execution of the three classification algorithms, the prediction of these classifiers will be a string that contains the 6 targets divided by a blank space. Hence, this output is split, in order to assess the 6 vulnerability characteristics and therefore, these characteristics are used to calculate the CVSS and WIVSS. An example that illustrates the whole process from the text analysis to the vulnerability severity scoring is given in the next paragraph.

In this example, the prediction of the vulnerability that was presented in Table 2 is demonstrated. The first step of the methodology takes as input the vulnerability description, executes the text analysis and the output is a DTM according to the terms existing in the training set. The corresponding DTM for this record is displayed in the Table 4 (only the terms that are appearing in this technical description are displayed in this table due to the large total number of terms), where the number shown corresponds to the term frequency in the description. Next, this DTM is used as input to the three classifiers (Random Forest, Boosting, Decision) that have been built having as dependent variable a string that contains the 6 targets and as independent variables the terms. All the three classifiers predicted correctly the class as {N L SI P N N}. After that, the predicted string will be split to the 6 corresponding targets {AV: N, AC: L, Au: SI, CI: P, II: N, AI: N}. Finally, by using these values, the formulas and the weights that were presented in the previous section, the CVSS and WIVSS scores could be easily calculated. Hence, the final scores are 4 for CVSS and 4.2 for WIVSS, which are also the final outputs of the proposed methodology.

Table 4: The DTM of the example

<i>aka</i> : 1	<i>authent</i> : 1	<i>code</i> : 1	<i>differ</i> : 1	<i>easier</i> : 1
<i>html</i> : 1	<i>install</i> : 2	<i>key</i> : 2	<i>leverage</i> : 1	<i>make</i> : 1
<i>obtain</i> : 1	<i>password</i> : 3	<i>remot</i> : 1	<i>service</i> : 1	<i>sourc</i> : 1
<i>use</i> : 1	<i>user</i> : 1			

The aforementioned methodology was implemented in the R⁹ statistical language, a rapidly developing open source language that has wide acceptance in the scientific community due to the expandability that offers through its packages (Voulgaropoulou et al., 2012). To implement the

⁹ <https://www.r-project.org/>

present research, the following R packages were used: tm¹⁰ and SnowballC¹¹ for the text analysis, ranger¹² for the classification with the Random Forest and C50¹³ for the classification with the Boosting and the Decision Tree. In parallel, scripting in R was used to implement the LP transformation algorithm. In order to balance the classes, and considering that the ranger and the C50 packages have the option to use different weights for each case, the cases are weighed in inversed proportion to the frequency of the class they belong. Hence, a case that belongs to a very rare class will take very big weight and a case that belongs to a very frequent class will take respectively a very small weight. The evaluation metrics that are analyzed in the next subsection (5.1 Validation), were calculated in the R and in Microsoft Excel. Finally, the results (tables and graphs) that will be presented in the next section were also created by using the R and the Microsoft Excel.

5.1. Validation

To validate the proposed methodology and specifically the vulnerability characteristic prediction, the following well-known evaluation metrics (Dembczyński et al., 2012, Zhang and Zhou, 2014) - which are suitable for the specific multi-target classification problem- were used.

- **Subset 0/1 loss:** $\frac{1}{n} \sum_{i=1}^n \mathbb{I}[Y^i \neq \hat{Y}^i]$, where n is the number of instances, $\hat{Y}^i$ is the predicted vector of targets for the i instance and Y^i is the actual vector. It is obvious, that this metric is particularly rigorous, since for an instance, the prediction is true only when all the targets have been estimated correctly.
- **Hamming loss:** $\frac{1}{n} \sum_{i=1}^n \frac{1}{m} \sum_{j=1}^m \mathbb{I}[y_j^i \neq \hat{y}_j^i]$, where m is the number of targets, $\hat{y}_j^i$ is the predicted value for the target j and instance i and the y_j^i is the actual value.

¹⁰ <https://cran.r-project.org/web/packages/tm/tm.pdf>

¹¹ <https://cran.r-project.org/web/packages/SnowballC/SnowballC.pdf>

¹² <https://cran.r-project.org/web/packages/ranger/ranger.pdf>

¹³ <https://cran.r-project.org/web/packages/C50/C50.pdf>

- **Accuracy:** $\frac{1}{m} \sum_{i=1}^m \frac{1}{q} \frac{\sum_{j=1}^q TP_{ij}}{TP_{ij} + FP_{ij} + TN_{ij} + FN_{ij}}$, where q is the number of classes for each target, TP_{ij} , are the True Positives for the target i and value j , FP_{ij} , are the False Positives, TN_{ij} and FN_{ij} , are the False Negatives.
- **Precision:** $\frac{1}{m} \sum_{i=1}^m \frac{1}{q} \sum_{j=1}^q \frac{TP_{ij}}{TP_{ij} + FP_{ij}}$
- **Recall:** $\frac{1}{m} \sum_{i=1}^m \frac{1}{q} \sum_{j=1}^q \frac{TP_{ij}}{TP_{ij} + FN_{ij}}$
- **F-measure:** $\frac{1}{m} \sum_{i=1}^m \frac{1}{q} \sum_{j=1}^q \frac{2 * Precision_{ij} * Recall_{ij}}{Precision_{ij} + Recall_{ij}}$

The first two *are example-based* evaluation measures from the multi-label literature, but instead of labels, here they are adapted to include targets. Respectively, the other four are based on the *label-based* measures from the multi-label literature and specifically, on the macro-averaged versions. It is obvious from the formulas that in this case, the first averaging part of each formula is as in the multi-label measures, but instead of labels here there is the averaging of the targets, while the second part is the computation of the corresponding well-established metrics of the multi-class (single target) classification. These four measures are also in accordance to the measures of Bielza et al. (2011) that deal with a multi-target classification problem. The Precision, the Recall and the F-measure are more strict and reliable measures in comparison with Accuracy. More specifically, the Precision measure represents the fraction of the true positives divided by the total predicted as positives, the Recall measure reflects the percentage of the true positives divided by the sum of the actual positives. Finally, the F-measure, is the harmonic mean of the Precision and the Recall.

Moreover, to validate the methodology regarding the vulnerability scoring, the metrics (Hyndman and Koehler, 2006) that are used to evaluate the scores, which are calculated from the predicted vector of vulnerability characteristics are the following:

- **Mean Absolute Error (MAE):** $\frac{1}{n} \sum_{i=1}^n |y_i - \hat{y}_i|$, where $\hat{y}_i$ is the predicted value and y_i is the actual.

- **Median Absolute Error (MdAE):** $median(|y_i - \hat{y}_i|)_{i=1}^n$
- **Root Mean Square Error (RMSE):** $\sqrt{\frac{\sum_{i=1}^n (y_i - \hat{y}_i)^2}{n}}$
- **Normalized Mean Absolute Error (NMAE):** $\frac{MAE}{\bar{y}}$, where $\bar{y}$ is the mean actual value.
- **Normalized Median Absolute Error (NMdAE):** $\frac{MdAE}{\bar{y}}$
- **Normalized Root Mean Square Error (NRMSE):** $\frac{RMSE}{\bar{y}}$

From the first three well-established measures in regression problems, **MdAE** is not affected by extreme values of errors in comparison with **MAE**, since is based on the median value. On the other hand, **RMSE** is stricter than **MAE** regarding the large errors, since is proportional to the squared error. Finally, the last three metrics are the normalized values of the first three measures, where the normalized factor is the mean actual value.

6. Results

The first step of the current methodology is the text analysis of the technical vulnerability description in order to result to the DTM. The final number of terms that are extracted from the text analysis is 258 and subsequently, this number represents the predictors of the multi-target classification.

Prior to the presentation of the multi-target classification results, we present a descriptive statistical analysis of the vulnerability characteristics in the dataset. The different vectors of vulnerability characteristics in the dataset are 337 (from 729 exhaustive possibilities) with frequencies, which range below 0.01% to 16.27%. The distribution of the vulnerability characteristics vectors as depicted in Figure 2, follows the power-law distribution, which can be met in a variety of phenomena and is based on the Pareto 80/20 rule (80% of the effects is derived from the 20% of the causes) (Newman, 2005). Table 5 displays the 10 most frequent multiple targets and as shown, their cumulative percentage is almost 70%. It is obvious, from both Figure 2 and Table 5 that the

majority of the vulnerability characteristic vectors have extremely low frequency percentages and this subsequently, makes the prediction of these vectors very difficult task.

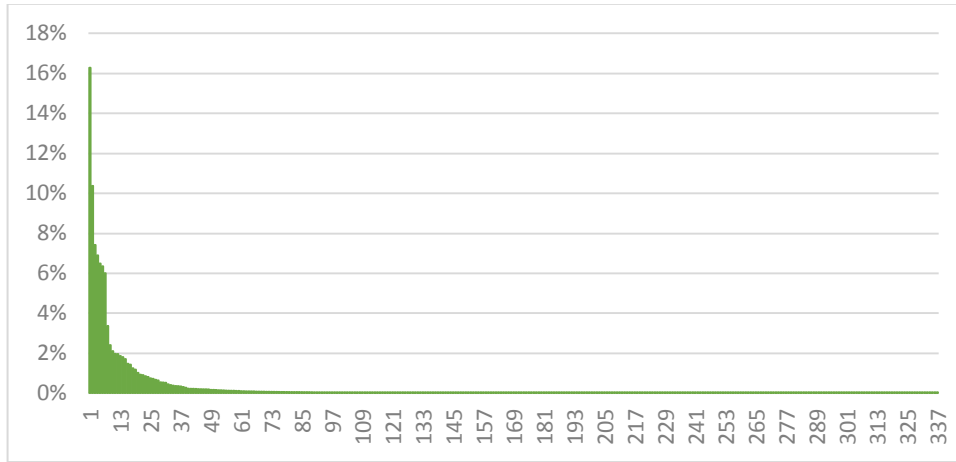


Figure 2: The distribution of the vulnerability characteristic vectors

Table 5: The 10 Most Frequent Multiple Targets

Vector of Multiple Targets	Frequency
AV: N, AC: L, Au: N, CI: P, II: P, AI: P	16.27%
AV: N, AC: M, Au: N, CI: N, II: P, AI: N	10.36%
AV: N, AC: M, Au: N, CI: P, II: P, AI: P	7.40%
AV: N, AC: L, Au: N, CI: C, II: C, AI: C	6.88%
AV: N, AC: L, Au: N, CI: P, II: N, AI: N	6.47%
AV: N, AC: M, Au: N, CI: C, II: C, AI: C	6.34%
AV: N, AC: L, Au: N, CI: N, II: N, AI: P	5.99%
AV: L, AC: L, Au: N, CI: C, II: C, AI: C	3.35%
AV: N, AC: M, Au: N, CI: N, II: N, AI: P	2.39%
AV: N, AC: L, Au: N, CI: N, II: P, AI: N	2.02%

6.1. Multi-target Classification Results

We present now the results of the multi-target classification for the evaluation of the proposed methodology. Table 6 shows the performance of the Random Forest, Boosting and Decision Tree algorithm according to the multi-target evaluation measures, which were presented in the previous section (Subset 0/1 Loss, Hamming loss, Accuracy, Precision, Recall, F-measure). The results are encouraging, especially for the Random Forest algorithm that has the best performance according to the 5 out of 6 evaluation measures. Regarding the strictest Subset 0/1 loss measure, the results

reflected that for the Random Forest and Boosting, over than 1 out of 4 vulnerabilities is estimated perfectly, while for the Decision Tree this number is only 1 out of 6.

Table 6: Prediction Results of Vulnerability Characteristics Vector

Accuracy Measure	Random Forest	Boosting	Decision Tree
Subset 0/1 Loss	73.6%	71.3%	84.3%
Hamming loss	28.5%	29.1%	37.8%
Accuracy	71.5%	70.9%	62.2%
Precision	59.4%	56.3%	50.0%
Recall	61.2%	56.3%	51.9%
F-measure	58.8%	55.5%	49.6%

In order to evaluate thoroughly the proposed methodology, an analysis regarding each vulnerability characteristic separately is following. The results for the Random Forest are displayed in Table 7 and Figure 3, for the Boosting in Figure 4 and Table 8 and finally, for the Decision Tree in Figure 5 and Table 9. Moreover, in order to compare the three machine learning algorithms, a comparative radar graph is shown in Figure 6, having as comparison measure the F-measure. It is obvious from the tables and the figures that the methodology present moderate to good performance and that the Random Forest is better than the other two algorithms. Regarding the F-measure, Random Forest is better than the other two methodologies the 5 out of 6 times. On the other hand, Decision Tree is the worst classifier the 5 out of 6 times.

Table 7: Prediction Results of Vulnerability Characteristics for Random Forest

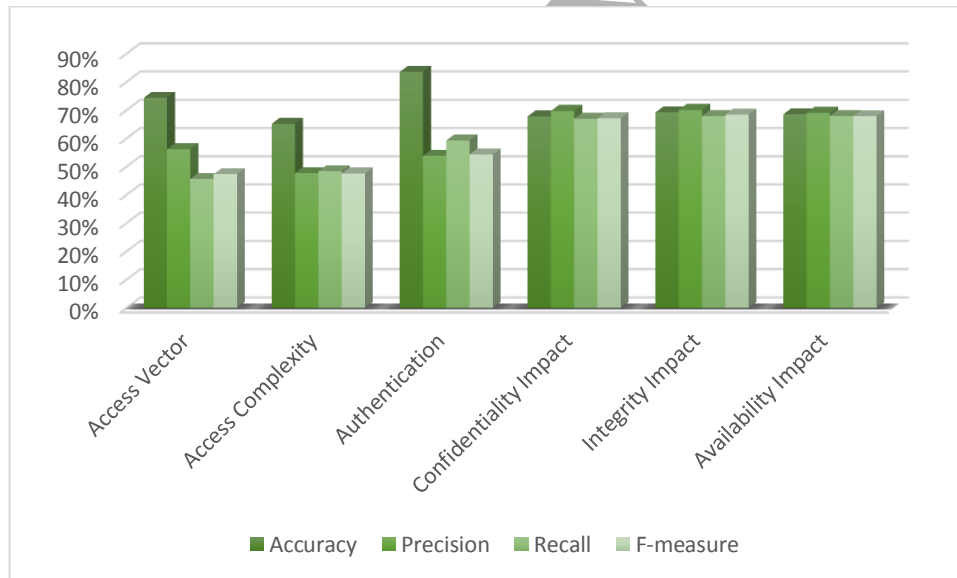
Vulnerability Characteristic	Accuracy	Precision	Recall	F-measure
Access Vector	74.43%	56.22%	45.70%	47.38%
Access Complexity	65.23%	47.76%	48.38%	47.63%
Authentication	83.59%	53.91%	59.30%	54.37%
Confidentiality Impact	67.85%	69.77%	67.03%	67.15%
Integrity Impact	69.26%	70.12%	67.95%	68.45%
Availability Impact	68.59%	69.11%	67.98%	67.91%

Table 8: Prediction Results of Vulnerability Characteristics for Boosting

Vulnerability Characteristic	Accuracy	Precision	Recall	F-measure
Access Vector	85.48%	62.57%	54.20%	57.13%
Access Complexity	61.46%	43.34%	45.17%	42.88%
Authentication	85.09%	41.78%	48.29%	43.52%
Confidentiality Impact	63.56%	62.62%	62.17%	62.14%
Integrity Impact	66.45%	64.65%	64.40%	64.37%
Availability Impact	63.66%	63.10%	63.29%	63.09%

Table 9 Prediction Results of Vulnerability Characteristics for Decision Tree

Vulnerability Characteristic	Accuracy	Precision	Recall	F-measure
Access Vector	64.45%	49.89%	41.73%	40.43%
Access Complexity	51.81%	39.42%	41.43%	39.19%
Authentication	79.68%	44.39%	43.28%	43.72%
Confidentiality Impact	59.42%	59.71%	57.87%	58.17%
Integrity Impact	60.64%	60.67%	59.00%	59.40%
Availability Impact	57.31%	57.52%	56.62%	56.85%

**Figure 3:** The bar-plot of the Vulnerability Characteristics Prediction for Random Forest

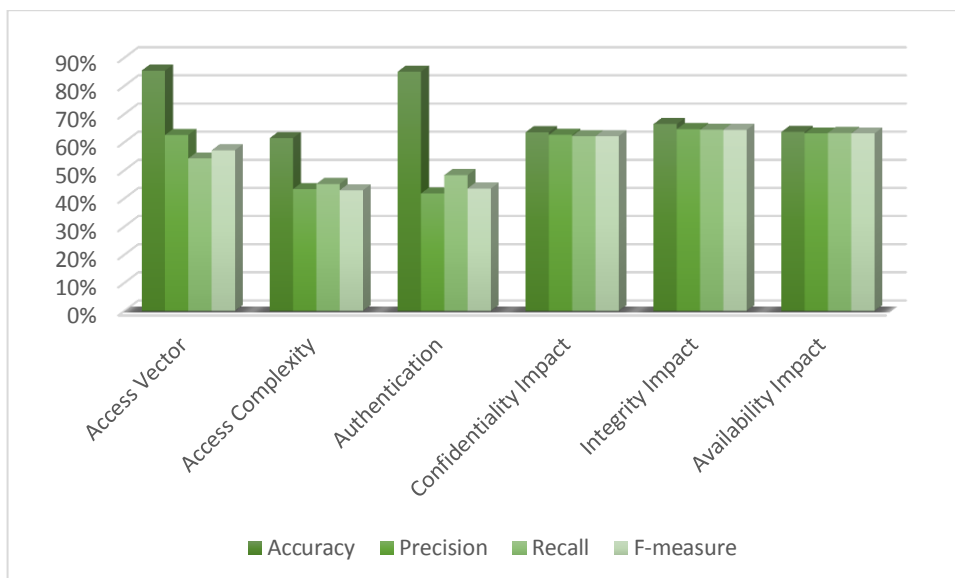


Figure 4: The bar-plot of the Vulnerability Characteristics Prediction for Boosting

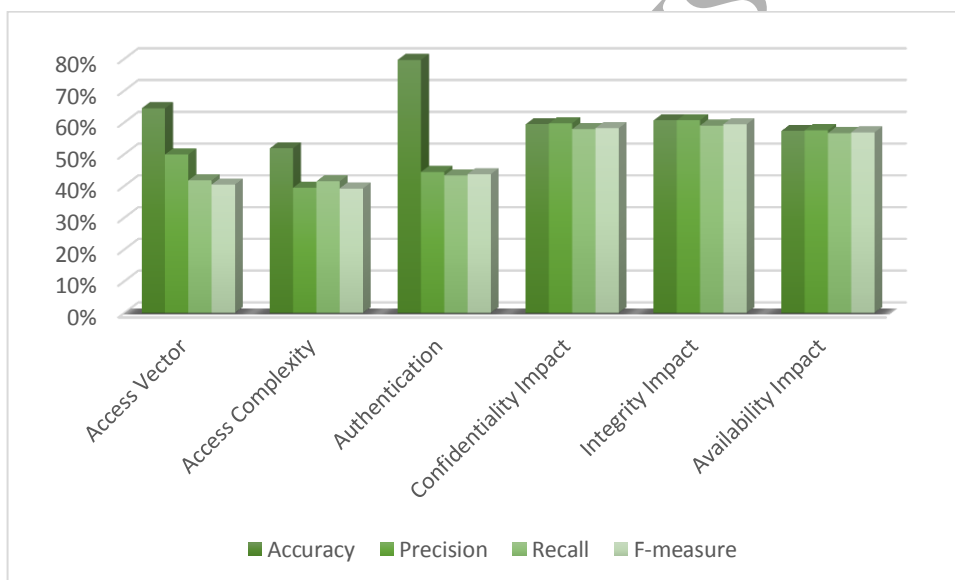


Figure 5: The bar-plot of the Vulnerability Characteristics Prediction for Decision Tree

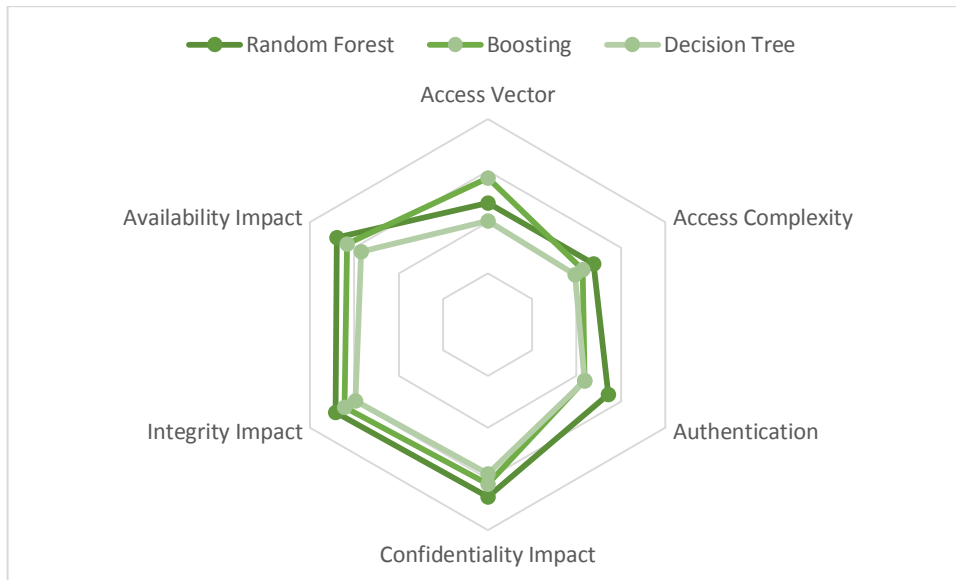


Figure 6: The Comparative Radar Graphs of the three models

The results of the proposed methodology using the Random Forest classifier (which was more accurate than the other two classifiers) are compared with that presented in the work of Yamamoto et al. (2015), who are the first that estimated the vulnerability characteristics from the technical description. The dataset of Yamamoto's study contains approximately 60,000 vulnerabilities from NVD having as test set the 1300 vulnerabilities. The results of this comparison having as comparison measure the F-measure are shown in Table 10 and Figure 7 (original results reported in Yamamoto et al, 2015). It is clear from the results that the performances of these two methodologies are very close.

Table 10: Comparative Results for the F-measure

Characteristic	Spanos and Angelis	Yamamoto et al.
Access Vector	47.38%	54.21%
Access Complexity	47.63%	46.83%
Authentication	54.37%	40.57%
Confidentiality Impact	67.15%	73.60%
Integrity Impact	68.45%	72.23%
Availability Impact	67.91%	76.00%

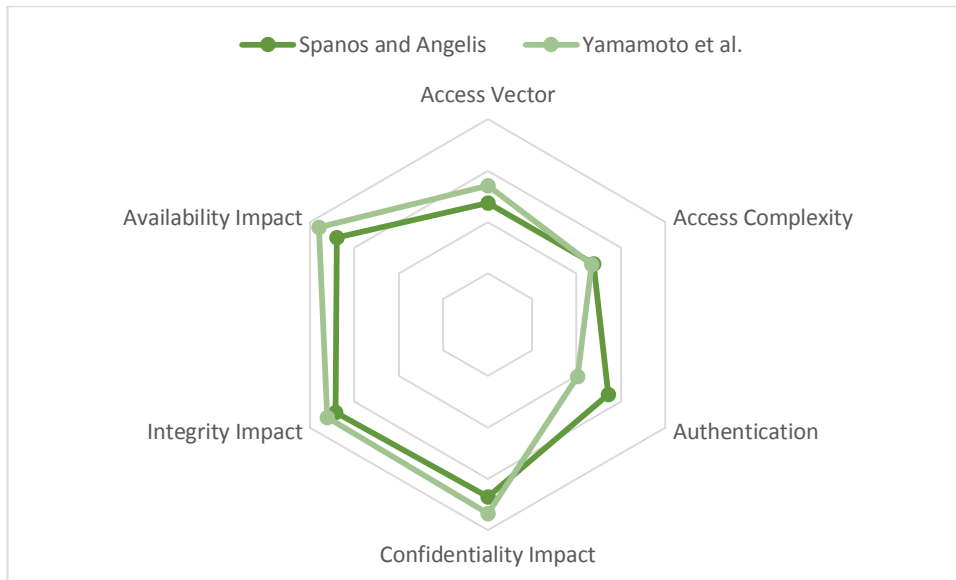


Figure 7: The Comparative Radar Graphs of the two methodologies

6.2. Vulnerability Scoring Results

The last part of the proposed methodology, considering that the vulnerability characteristics constitute the input of the vulnerability scoring systems, is the calculation of the CVSS and WIVSS scores from the predicted vulnerability characteristics and the comparison with the actual values calculated from the actual vulnerability characteristic vector. Once again, due to its better performance, only the Random Forest classifier was used for the calculation of the CVSS and WIVSS. The mean values of actual CVSS and WIVSS are 5.95 and 5.5 respectively, while the calculated values from the predicted characteristics are close: 5.22 for CVSS and 4.98 for WIVSS. Moreover, the correlation between actual and predicted value is moderate: 0.49 ($p < 0.01$) and 0.56 ($p < 0.01$) for CVSS and WIVSS respectively. Table 11 shows the accuracy measures (MAE, MdAE, RMSE, and the corresponding normalized measure) for both CVSS and WIVSS. Finally, in Figure 8 and 9 the histograms of the CVSS and WIVSS prediction errors are shown. It is clear that for both scoring systems the vast majority of errors is in the range [0,0.5].

Table 11: Accuracy in Vulnerability Scores Prediction

Scoring System	MAE	MdAE	RMSE	NMAE	NMdAE	NRMSE
CVSS	1.74	1.40	2.54	29.27%	23.53%	42.69%
WIVSS	1.59	1.00	2.45	28.90%	18.20%	44.52%

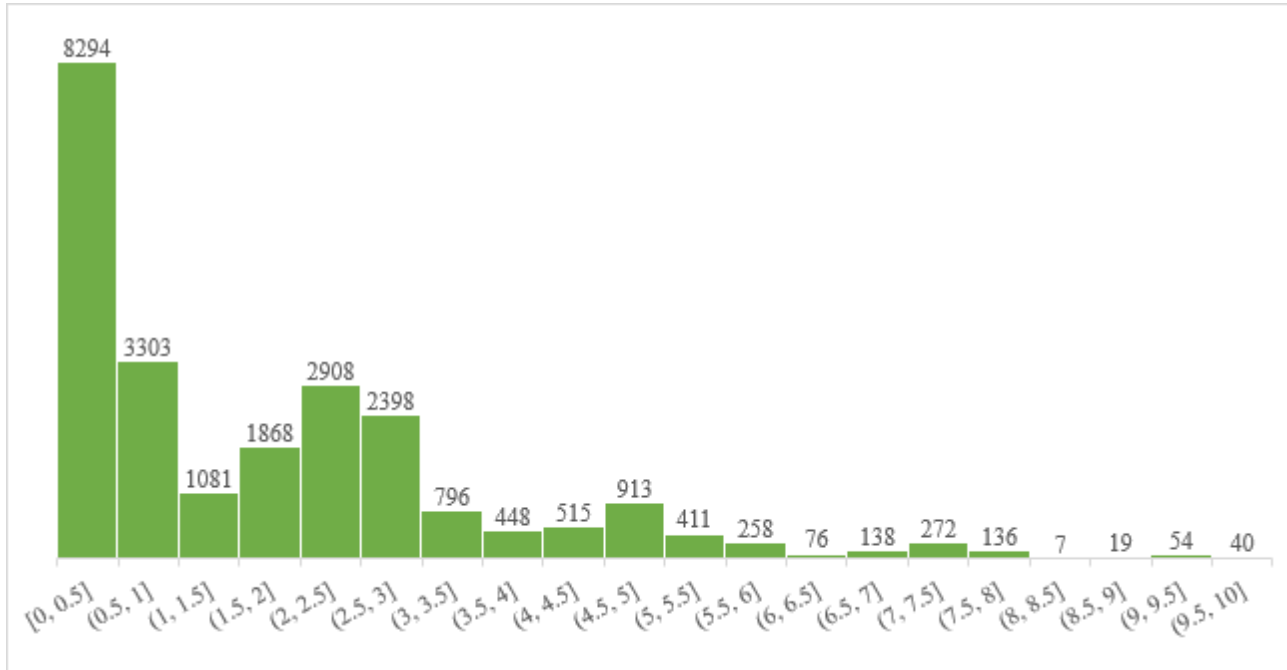


Figure 8: The Histogram of CVSS prediction errors

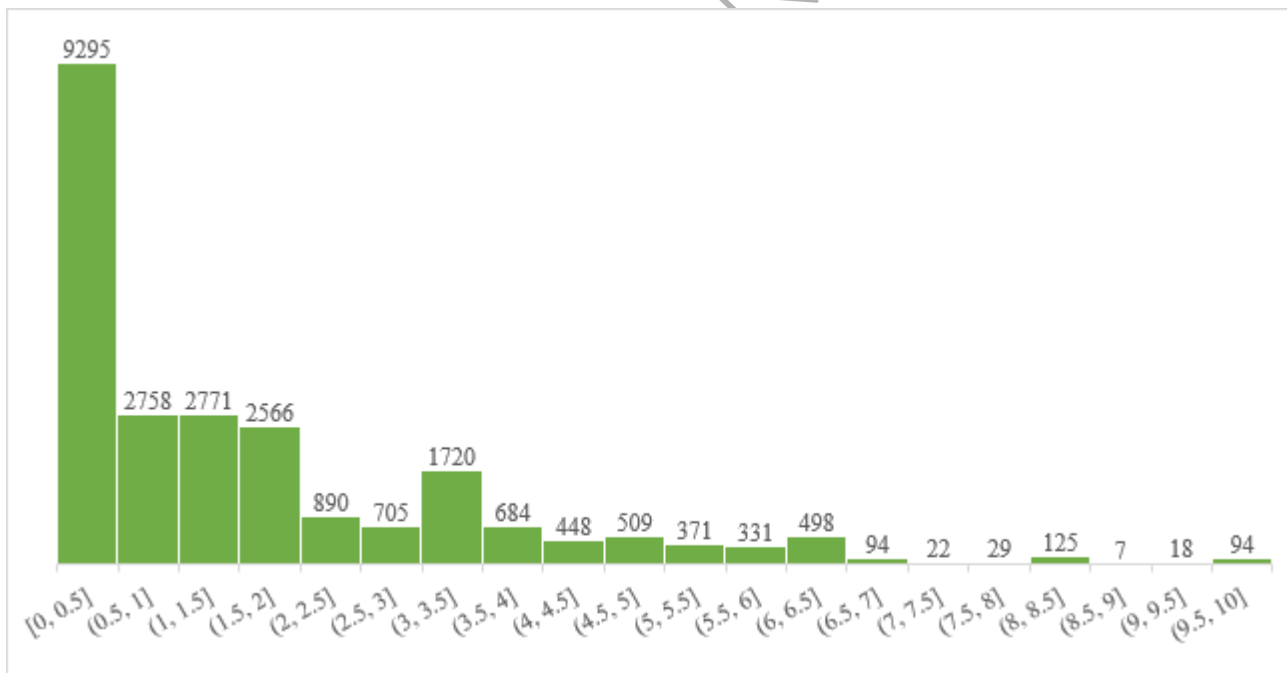


Figure 9: The Histogram of WIVSS prediction errors

As discussed in the previous sections, the vulnerability scores, which are derived from the vulnerability scoring systems, determine the prioritization of the vulnerabilities in the fixing procedure. Considering the managerial impact of the most critical vulnerabilities and taking into

account the NVD methodology that characterizes the vulnerabilities as High Severity those with scores ranging from 7 to 10, we compute also the evaluation measures (a) only for the Critical Vulnerabilities (score ≥ 7) and (b) only for the predicted as Critical Vulnerabilities (which in the cases of large errors constitute false alarms). The results of these experiments according to the evaluation measures are displayed in Tables 12-13. Furthermore, the four histograms of Figures 10-13 depict the distribution of errors and it is obvious that the clear majority of prediction errors, ranges between 0 and 0.5 for both systems and for both the Critical vulnerabilities and the Predicted as Critical Vulnerabilities.

Table 12: Accuracy in Vulnerability Scores Prediction (Critical Vulnerabilities)

Scoring System	MAE	MdAE	RMSE	NMAE	NMdAE	NRMSE
CVSS	2.12	1.70	3.11	25.38%	20.38%	37.35%
WIVSS	2.04	0.80	3.34	22.22%	8.70%	36.38%

Table 13: Accuracy in Vulnerability Scores Prediction (Predicted Critical Vulnerabilities)

Scoring System	MAE	MdAE	RMSE	NMAE	NMdAE	NRMSE
CVSS	1.57	1.70	2.21	20.88%	22.54%	29.36%
WIVSS	1.84	1.10	2.61	23.97%	14.34%	34.03%

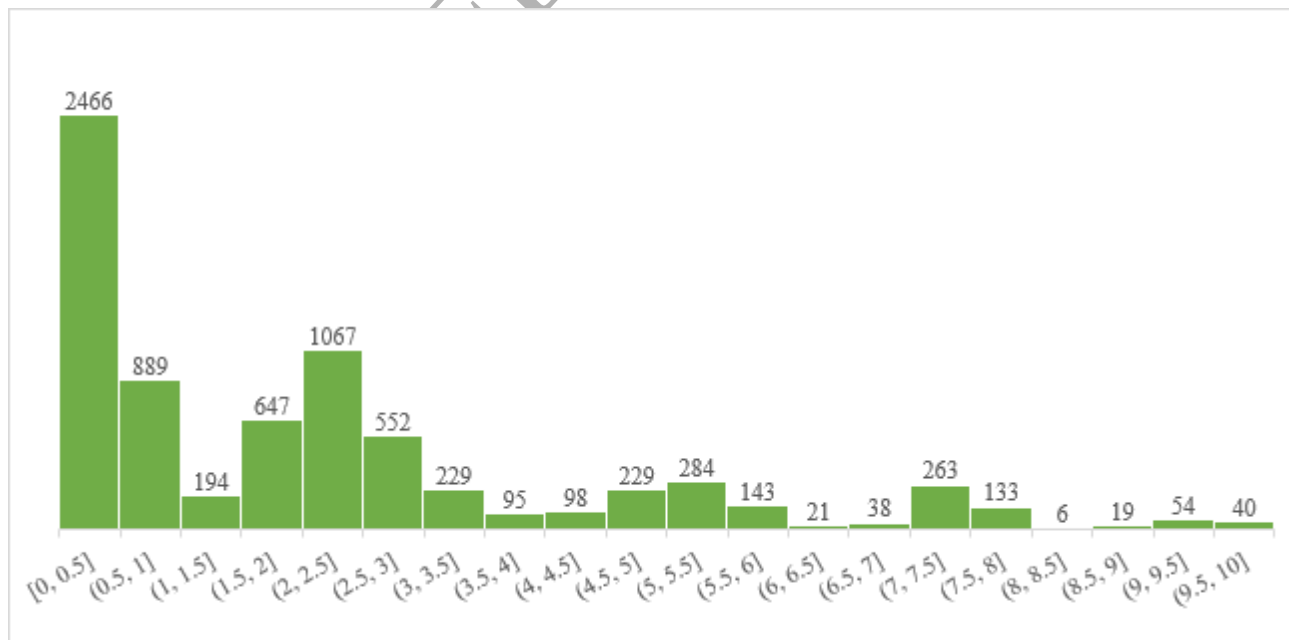


Figure 10: The Histogram of CVSS prediction errors (Critical Vulnerabilities)

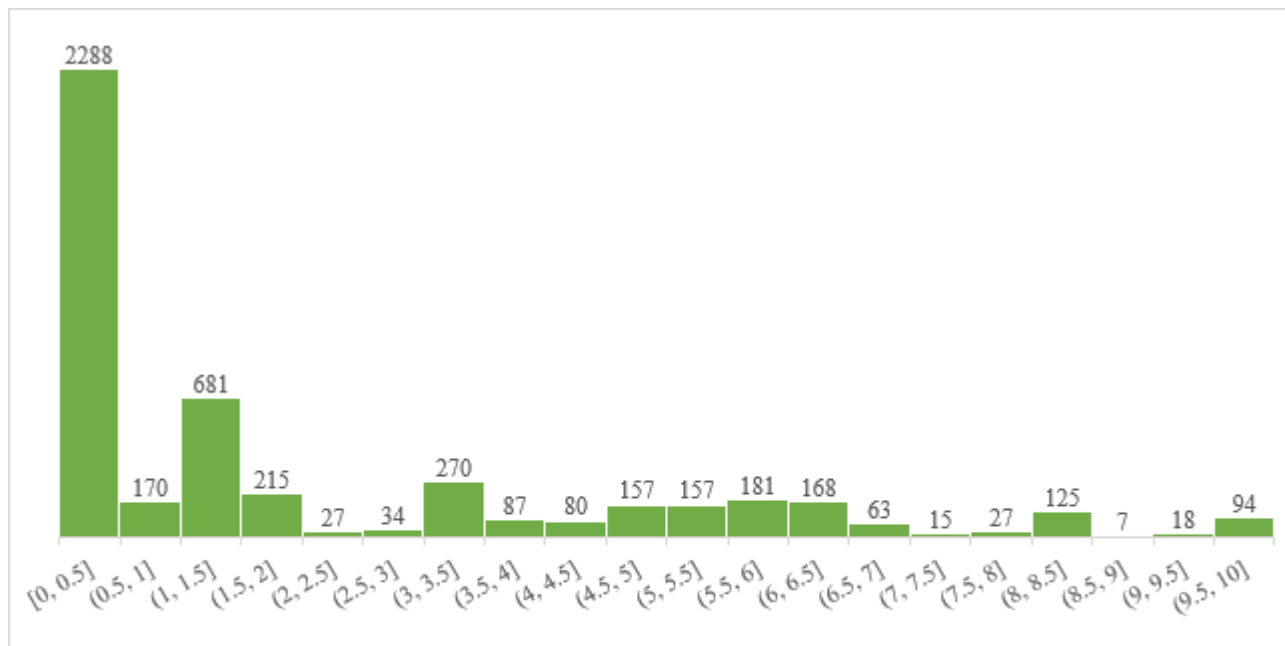


Figure 11: The Histogram of WIVSS prediction errors (Critical Vulnerabilities)

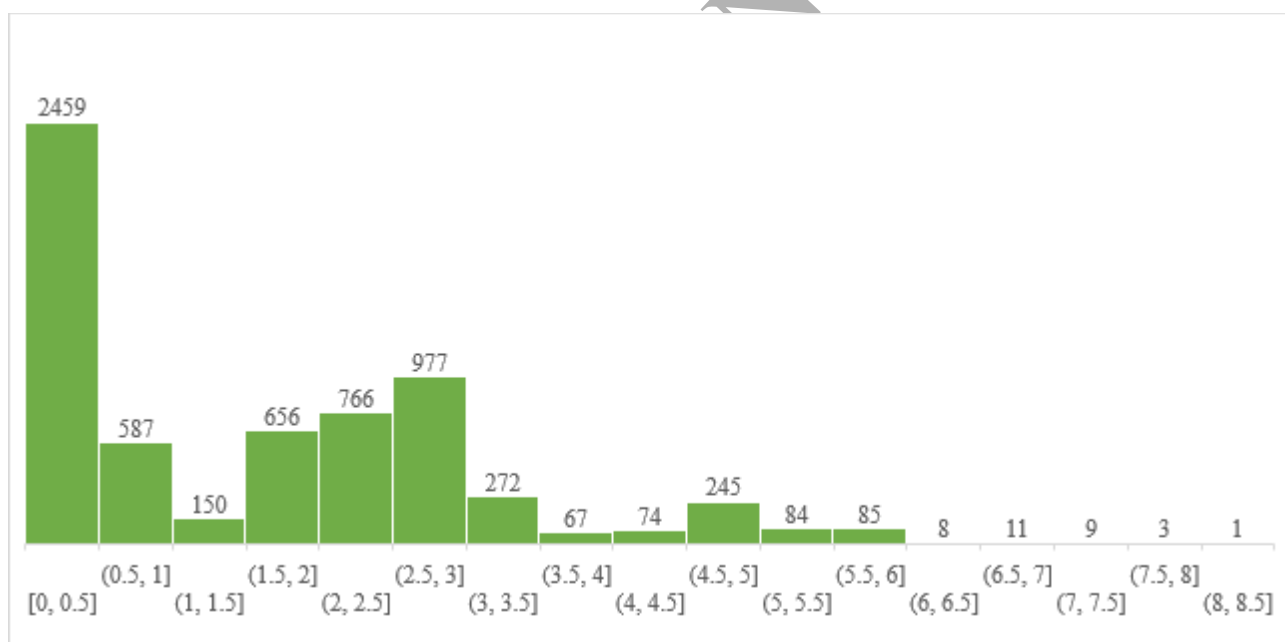


Figure 12: The Histogram of CVSS prediction errors (Predicted Critical Vulnerabilities)

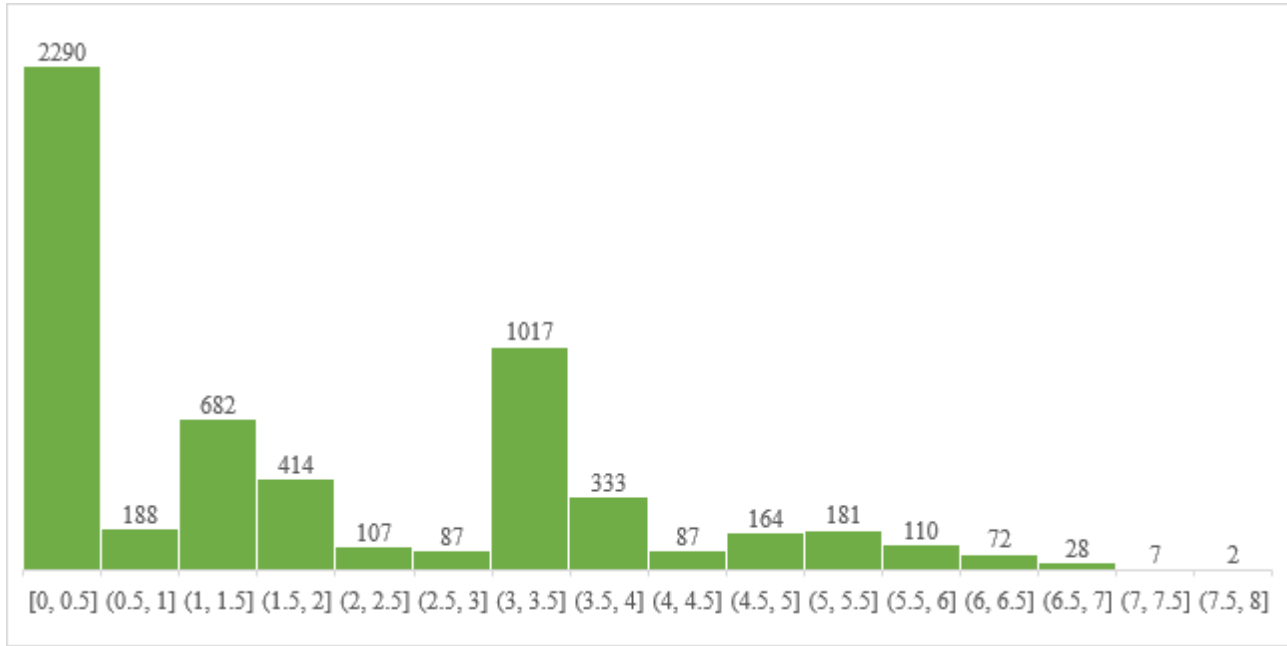


Figure 13: The Histogram of WIVSS prediction errors (Predicted Critical Vulnerabilities)

7. Discussion

The methodology that was presented in this paper and the derived model can potentially be the basis for a simple system (such as a web page running R in the background) that will take as input a text related to a vulnerability (technical description from CVE) and will produce as output the estimation of the vulnerability characteristics and the severity scores. It is obvious that no previous training is needed to use a system like this and only the knowledge of the vulnerability properties is a pre-requisite in order to understand the output of the system. As already mentioned in the introduction, this system could be a useful tool for the security experts, the software vendors, the software developers and the simple users.

Regarding the multi-target classification results, the three algorithms presented a moderate to good performance. Generally, the results of the Random Forest algorithm showed good performance, however, for some vulnerability characteristics (Access Vector and Access Complexity) the results are not so good and it needs more attention. The Boosting algorithm came second, but close to the Random Forest, while the Decision Tree presented the worst performance of the three machine learning algorithms.

The current methodology using the Random Forest algorithm was compared with the previous work of Yamamoto et al. (2015). The comparison graph between the two methodologies and the corresponding table that presented in the previous section, depicted that the two methodologies are comparable. These comparative results are very encouraging for the proposed methodology, since, without the use of any factor (as the annual effect in the work of Yamamoto et al. (2015) apart from the technical terms and the use of a simple multi-label algorithm that however, considers the relations between the characteristics, the results are similar. Hence, the multi-target approach of the current methodology achieved its purpose regarding the performance.

The last step of the present methodology is the calculation of the vulnerability severity scores (CVSS & WIVSS). The results that were presented in the previous section are also, encouraging. More, specifically, the accuracy according to the three evaluation measures used and to the corresponding normalized measures, reflects that the proposed methodology can predict sufficiently the vulnerability scores of CVSS & WIVSS. Moreover, the distribution of errors as shown in the 6 histograms (for all the vulnerabilities, for the critical, and for the predicted as critical), depicted that there are not many failures (very big errors) in the prediction of both vulnerability scoring systems and most of the times the error is very small. Finally, the small difference in the mean values of the actual and the predicted values, as well the moderate correlation between these values (for both CVSS & WIVSS), enhances the claim that the proposed methodology can predict relatively good the vulnerability scores.

In every empirical work such as the present research, there are threats to the validity and these threats will be discussed in this section. In the present empirical work, the validity issues that will be analyzed below concern two specific aspects: a) **internal validity** (reliability) and b) **external validity** (generalizability) (Wieringa and Daneva, 2015; Jalali et al., 2014).

The first point of bias that can be discussed is stemmed from the selection of the vulnerability database. At this moment, NVD constitutes the largest publicly available database and this fact facilitates the verification of the presented results and the validation of the proposed methodology.

The magnitude and the data availability of the NVD are the main reasons for a vulnerability researcher to choose the NVD as primary source. As validated from the related literature, NVD is the first and probably, the only reliable choice for any empirical work in the field of software vulnerabilities. Alternatively, a researcher should search for non-technical databases and collect vulnerability data from social media and technological portals.

Another worth-mentioning threat to validity, is the vulnerability sample selection. The purpose of this empirical study was to include as many as possible vulnerabilities in the sample and for this reason, the whole dataset of the NVD from 1988 until 2018 (almost 100,000 vulnerabilities) is included in the research sample. This huge number of vulnerabilities that constitutes the biggest number used in the related literature aims in the generalization of the results, at least regarding the vulnerabilities registered in NVD. However, the generalization of results to other databases using different descriptions and characterizations is not straightforward. The proposed methodologies should be adapted, trained and evaluated accordingly. It is also worth mentioning that the last two years there is a new vulnerability schema in NVD, but only available for the newest vulnerabilities. This new schema was not considered in our study, since as mentioned previously, the aim was to include a large number of vulnerabilities, covering a long-time period.

Finally, the last threat to the validity of the proposed methodology is stemmed from the selection of the evaluation measures. Of course, the pool of the evaluation measures is endless, so we included the most well-known and well-established evaluation metrics in the literature, regarding both the classification part and the score prediction. For this reason, overall 12 different metrics (6 for the classification and 6 for the score prediction) were selected to evaluate the present research study.

Continuing with the weaknesses of the proposed methodology, first, regarding the LP transformation algorithm, one of the techniques that are used in the proposed methodology, although it is a straightforward transformation algorithm, it has the disadvantage of creating a large number of classes. This subsequently, in the current research, led (due to the structure of the

dataset) to unbalanced classes, which were balanced artificially by weighing the cases according to the class that belong.

Second, as described in the first step of the methodology, the methodology takes as input the technical description of the vulnerabilities. It is therefore difficult for the model that was built, to be efficient and accurate in the prediction of the vulnerability characteristics when the input is a non-technical text (as the text derived from technological portals and social media). Free text probably will not contain specific key-terms that exist in the vulnerability summary of the NVD and hence, the estimation of characteristics will be much more difficult as a task.

8. Conclusions

In this paper, text analysis and multi-target classification techniques were combined in order to create a model that will estimate the vulnerability characteristics and scores from the technical description. The purpose of this methodology and by extension, the purpose of this paper is the enhancement, the acceleration and the support of the vulnerability characteristic specification that now, is conducted by the IT security experts. A future system that will be based on the proposed methodology, will not substitute the human factor, but could be act as a recommendation system that will help the security experts to take critical decisions more quickly and accurately.

The results clearly indicate that the proposed methodology can achieve the purpose of this research, since the accuracy in the prediction of the vulnerability characteristics is good, validated by several accuracy measures. Furthermore, the comparison with the previous work of Yamamoto et al., (2015) highlighted that the proposed methodology with the multi-target approach, could achieve comparable results. Moreover, the good accuracy of the calculated vulnerability scores CVSS & WIVSS from the predicted characteristics, reflects that the proposed methodology could also highlights the vulnerability severity, which is very crucial from a managerial perspective (especially, for the Critical and the Estimated as Critical Vulnerabilities), since the severity defines and prioritizes the software patching procedure and subsequently, affects the resource management.

The novelty of this research is the consideration of the vulnerability characteristics as a vector of six targets and subsequently, the estimation of these characteristics using multi-target classification, which constitutes a generalization of the multi-label classification. At this point, it is important to mention that there is a plethora of multi-target algorithms, but the purpose of this study is not a comparative analysis between different algorithms, but the introduction of the multi-target approach in the vulnerability characteristic prediction. Hence, the selection of the LP transformation algorithm, which is a benchmark algorithm in the multi-label classification literature along with the encouraging results, lead us to the conclusion that estimation of the vulnerability characteristics, using text analysis and multi-target classification deserves further research. Moreover, as a future research an interesting direction is the handling of the problem of minority classes by different algorithms existing in the multi-label classification literature (Tsoumakas et al., 2011), since the LP algorithm results in very unbalanced distribution of classes.

References

- Balan, S., and Conlon, S. (2016). Text Analysis of Green Supply Chain Practices in Healthcare. *Journal of Computer Information Systems*, 1-9.
- Belayneh, A., Adamowski, J., Khalil, B., and Quilty, J. (2016). Coupling machine learning methods with wavelet transforms and the bootstrap and boosting ensemble approaches for drought prediction. *Atmospheric Research*, 172, 37-47.
- Bielza, C., Li, G., and Larranaga, P. (2011). Multi-dimensional classification with Bayesian networks. *International Journal of Approximate Reasoning*, 52(6), 705-727.
- Bogaert, M., Ballings, M., and Van den Poel, D. (2016). The added value of Facebook friends data in event attendance prediction. *Decision Support Systems*, 82, 26-34.
- Boutell, M. R., Luo, J., Shen, X., and Brown, C. M. (2004). Learning multi-label scene classification. *Pattern recognition*, 37(9), 1757-1771.
- Breiman, L. (1996). Bagging predictors. *Machine learning*, 24(2), 123-140.

Breiman, L. (2001). Random forests. *Machine learning*, 45(1), 5-32.

Caruana, R., Karampatziakis, N., and Yessenalina, A. (2008, July). An empirical evaluation of supervised learning in high dimensions. In *Proceedings of the 25th international conference on Machine learning* (pp. 96-103). ACM.

Caruana, R., and Niculescu-Mizil, A. (2006, June). An empirical comparison of supervised learning algorithms. In *Proceedings of the 23rd international conference on Machine learning* (pp. 161-168). ACM.

Cerri, R., da Silva, R. R., and de Carvalho, A. C. (2009, July). Comparing methods for multilabel classification of proteins using machine learning techniques. In *Brazilian Symposium on Bioinformatics* (pp. 109-120). Springer Berlin Heidelberg.

Cesa-Bianchi, N., Re, M., and Valentini, G. (2012). Synergy of multi-label hierarchical ensembles, data fusion, and cost-sensitive methods for gene functional inference. *Machine Learning*, 88(1-2), 209-241.

Chan, S. W., and Chong, M. W. (2017). Sentiment analysis in financial texts. *Decision Support Systems*, 94, 53-64.

Chasaki, D., and Mansour, C. (2015). Security challenges in the internet of things. *International Journal of Space-Based and Situated Computing*, 5(3), 141-149.

Cheng, W., and Hüllermeier, E. (2009). Combining instance-based learning and logistic regression for multilabel classification. *Machine Learning*, 76(2-3), 211-225.

Chen, X., Bose, I., Leung, A. C. M., and Guo, C. (2011). Assessing the severity of phishing attacks: A hybrid data mining approach. *Decision Support Systems*, 50(4), 662-672.

Chowdhury, G. G. (2003). Natural language processing. *Annual review of information science and technology*, 37(1), 51-89.

Dembczyński, K., Waegeman, W., Cheng, W., and Hüllermeier, E. (2012). On label dependence and loss minimization in multi-label classification. *Machine Learning*, 88(1-2), 5-45.

Fernández-Delgado, M., Cernadas, E., Barro, S., and Amorim, D. (2014). Do we need hundreds of classifiers to solve real world classification problems? *J. Mach. Learn. Res*, 15(1), 3133-3181.

First Organization (2015, June). Common Vulnerability Scoring System v3.0: User Guide. https://www.first.org/cvss/cvss-v30-user_guide_v1.4.pdf. Accessed 14.07.2017.

Freund, Y., and Schapire, R. E. (1997). A decision-theoretic generalization of on-line learning and an application to boosting. *Journal of computer and system sciences*, 55(1), 119-139.

Ghaffarian, S. M., and Shahriari, H. R. (2017). Software Vulnerability Analysis and Discovery Using Machine-Learning and Data-Mining Techniques: A Survey. *ACM Computing Surveys (CSUR)*, 50(4), 56.

Ho, T. K. (1998). The random subspace method for constructing decision forests. *IEEE Transactions on Pattern Analysis and Machine Intelligence*, 20(8), 832-844.

Huang, C., Ai, H., Li, Y., and Lao, S. (2005, October). Vector boosting for rotation invariant multi-view face detection. In *Computer Vision, 2005. ICCV 2005. Tenth IEEE International Conference on* (Vol. 1, pp. 446-453). IEEE.

Hyndman, R. J., and Koehler, A. B. (2006). Another look at measures of forecast accuracy. *International journal of forecasting*, 22(4), 679-688.

Jalali, S., Wohlin, C., & Angelis, L. (2014). Investigating the applicability of agility assessment surveys: A case study. *Journal of Systems and Software*, 98, 172-190.

Kuhn, M., and Johnson, K. (2013). *Applied predictive modeling* (Vol. 26). New York: Springer.

Kuzuno, H., & Tonami, S. (2015). Detection of sensitive information leakage in Android applications using signature generation. *International Journal of Space-Based and Situated Computing*, 5(1), 53-62.

Liaw, A., and Wiener, M. (2002). Classification and regression by randomForest. *R news*, 2(3), 18-22.

Liu, C., Li, J., and Chen, X. (2012, March). Network vulnerability analysis using text mining. *In Asian Conference on Intelligent Information and Database Systems* (pp. 274-283). Springer Berlin Heidelberg.

Liu, Q., and Zhang, Y. (2011). VRSS: A new system for rating and scoring vulnerabilities. *Computer Communications*, 34(3), 264-273.

Liu, Q., Zhang, Y., Kong, Y., and Wu, Q. (2012). Improving VRSS-based vulnerability prioritization using analytic hierarchy process. *Journal of Systems and Software*, 85(8), 1699-1708.

Luan, S. (2016). Exploit two Xen hypervisor vulnerabilities. <https://www.blackhat.com/docs/us-16/materials/us-16-Luan-Ouroboros-Tearing-Xen-Hypervisor-With-The-Snake-wp.pdf>.

Accessed 14.07.2018.

Meire, M., Ballings, M., and Van den Poel, D. (2016). The added value of auxiliary data in sentiment analysis of Facebook posts. *Decision Support Systems*, 89, 98-112.

Mell, P., Scarfone, K., and Romanosky, S. (2007, June). A Complete Guide to the Common Vulnerability Scoring System Version 2.0. <https://www.first.org/cvss/cvss-v2-guide.pdf>.

Accessed 14.07.2017.

Mencia, E. L., and Fürnkranz, J. (2008, September). Efficient pairwise multilabel classification for large-scale problems in the legal domain. *In Joint European Conference on Machine Learning and Knowledge Discovery in Databases* (pp. 50-65). Springer Berlin Heidelberg.

Meng, N., Wang, J., Kodama, E., and Takata, T. (2013). Reducing data leakage possibility resulted from eavesdropping in wireless sensor network. *International Journal of Space-Based and Situated Computing* 6, 3(1), 55-65.

Murtaza, S. S., Khreich, W., Hamou-Lhadj, A., and Bener, A. B. (2016). Mining trends and patterns of software vulnerabilities. *Journal of Systems and Software*, 117, 218-228.

Na, S., Kim, T., and Kim, H. (2016, November). A Study on the Classification of Common Vulnerabilities and Exposures using Naïve Bayes. In *International Conference on Broadband and Wireless Computing, Communication and Applications* (pp. 657-662). Springer International Publishing.

Neuhaus, S., and Zimmermann, T. (2010, November). Security trend analysis with cve topic models. In *Software reliability engineering (ISSRE), 2010 IEEE 21st international symposium on* (pp. 111-120). IEEE.

Newman, M. E. (2005). Power laws, Pareto distributions and Zipf's law. *Contemporary physics*, 46(5), 323-351.

Nishanth, K. J., Ravi, V., Ankaiah, N., and Bose, I. (2012). Soft computing based imputation and hybrid data and text mining: The case of predicting the severity of phishing alerts. *Expert Systems with Applications*, 39(12), 10583-10589.

Quinlan, J. R. (1993). *C4. 5: Programs for Machine Learning*. Morgan Kaufmann.

Roumani, Y., Nwankpa, J. K., and Roumani, Y. F. (2015). Time series modeling of vulnerabilities. *Computers & Security*, 51, 32-40.

Rulequest Research (2017). Is See5/C5.0 Better Than C4.5? <http://www.rulequest.com/see5-comparison.html>. Accessed 14.07.2017.

Rulequest Research (2018). Data Mining Tools See5 and C5.0. <http://www.rulequest.com/see5-info.html>. Accessed 14.07.2017.

Ruohonen, J. (2017). A Look at the Time Delays in CVSS Vulnerability Scoring. *Applied Computing and Informatics*.

Ruohonen, J., Hyrynsalmi, S., and Leppänen, V. (2015). The sigmoidal growth of operating system security vulnerabilities: An empirical revisit. *Computers & Security*, 55, 1-20.

Peng, S., Cui, B., Jia, R., Liang, S., and Zhang, Y. (2013). A novel vulnerability detection method for ZigBee MAC layer. *International Journal of Grid and Utility Computing*, 4(2-3), 134-143.

Schiffman, M., and Cisco, C. I. A. G. (2005, June). A complete guide to the common vulnerability scoring system (CVSS). <http://www.first.org/cvss/v1/guide>. Accessed 07.07.2017.

Spanos, G., and Angelis, L. (2015). Impact metrics of security vulnerabilities: Analysis and weighing. *Information Security Journal: A Global Perspective*, 24(1-3), 57-71.

Spanos, G., Angelis, L., and Toloudis, D. (2017, September). Assessment of Vulnerability Severity using Text Mining. In *Proceedings of the 21st Pan-Hellenic Conference on Informatics* (p. 49). ACM.

Spanos, G., Sioziou, A., and Angelis, L. (2013, September). WIVSS: a new methodology for scoring information systems vulnerabilities. In *Proceedings of the 17th Panhellenic Conference on Informatics* (pp. 83-90). ACM.

Theodosiou, T., Angelis, L., and Vakali, A. (2008). Non-linear correlation of content and metadata information extracted from biomedical article datasets. *Journal of Biomedical Informatics*, 41(1), 202-216.

Toloudis, D., Spanos, G., and Angelis, L. (2016, June). Associating the Severity of Vulnerabilities with their Description. In *International Conference on Advanced Information Systems Engineering* (pp. 231-242). Springer International Publishing.

Tsoumakas, G., and Katakis, I. (2006). Multi-label classification: An overview. *International Journal of Data Warehousing and Mining*, 3(3).

Tsoumakas, G., Katakis, I., and Vlahavas, I. (2011). Random k-labelsets for multilabel classification. *IEEE Transactions on Knowledge and Data Engineering*, 23(7), 1079-1089.

Tsoumakas, G., Papadopoulos, A., Qian, W., Vologianidis, S., D'yakonov, A., Puurula, A., Read, J., Svec, J., and Semenov, S. (2014, October). WISE 2014 challenge: Multi-label classification of print media articles to topics. *In International Conference on Web Information Systems Engineering* (pp. 541-548). Springer International Publishing.

Von Alan, R. H., March, S. T., Park, J., and Ram, S. (2004). Design science in information systems research. *MIS quarterly*, 28(1), 75-105.

Voulgaropoulou, S., Spanos, G., and Angelis, L. (2012, October). Analyzing measurements of the R statistical open source software. *In Software Engineering Workshop (SEW), 2012 35th Annual IEEE* (pp. 1-10). IEEE.

Wieringa, R. J. (2014). *Design Science Methodology for Information Systems and Software Engineering*. Springer.

Wieringa, R., and Daneva, M. (2015). Six strategies for generalizing software engineering theories. *Science of computer programming*, 101, 136-152.

Williams, G. (2016). Hands-On Data Science with R Text Mining. <https://onepager.togaware.com/TextMiningO.pdf>. Accessed 23.06.18.

Xioufis, E. S., Sechidis, K., Tsoumakas, G., and Vlahavas, I. (2011) Mlkd's participation at the clef 2011 photo annotation and concept-based retrieval tasks. *In ImageCLEF Lab of CLEF 2011 Conference on Multilingual and Multimodal Information Access Evaluation*.

Xioufis, E. S., Tsoumakas, G., Groves, W., and Vlahavas, I. (2016). Multi-target regression via input space expansion: treating targets as inputs. *Machine Learning*, 104(1), 55-98.

Xioufis, E. S., Tsoumakas, G., and Vlahavas, I. (2011, June). Multi-label learning approaches for music instrument recognition. *In International Symposium on Methodologies for Intelligent Systems* (pp. 734-743). Springer Berlin Heidelberg.

Yamamoto, Y., Miyamoto, D., and Nakayama, M. (2015, November). Text-Mining Approach for Estimating Vulnerability Score. *In Building Analysis Datasets and Gathering Experience Returns for Security (BADGERS), 2015 4th International Workshop on* (pp. 67-73). IEEE.

Zhang, M. L., and Zhou, Z. H. (2014). A review on multi-label learning algorithms. *IEEE transactions on knowledge and data engineering*, 26(8), 1819-1837.

Zhang, S., Ou, X., and Caragea, D. (2015). Predicting cyber risks through national vulnerability database. *Information Security Journal: A Global Perspective*, 24(4-6), 194-206.

Georgios Spanos was born in Thessaloniki, on November 13, 1985. He received his BSc degree in Informatics and his MSc degree in Informatics and Management from Aristotle University of Thessaloniki (AUTH). He is currently a PhD Candidate in Informatics at Aristotle University of Thessaloniki (AUTH) and a Professional Software Engineer. His main research interests are: Statistical Methods, Machine Learning Techniques and Information Security.

Lefteris Angelis studied Mathematics and received his Ph.D. degree in Statistics from Aristotle University of Thessaloniki (A.U.Th.). He is currently a Professor at the Department of Informatics of A.U.Th and coordinator of the STAINS (STAtistics and INformation Systems) research group. His research interests involve statistical methods with applications to information systems and software engineering, especially regarding the research on the human factor, computational methods in mathematics and statistics, planning of experiments and simulation techniques.